Procedimiento de Control de la Información Documentada

ISO/IEC 27001:2022 — Cláusula 7.5

Código de documento	SGSI-DOC-002	**Versión**	1.6
Estado	Borrador	**Clasificación**	Interna
Propietario	Dirección General — Atalaya GP SL	**Autor**	El consultor (externo)
Fecha de emisión	22/05/2026	**Fecha de aprobación**	Pendiente
Aprobado por	Pendiente conforme a DOC-002 §4	**Registro de aprobación**	Sin acta de aprobación de esta revisión. No acredita implantación ni firma contractual.

Historial de versiones

Versión	Fecha	Autor	Descripción del cambio
0.1	22/05/2026	El consultor	Emisión inicial
1.0	05/06/2026	Comité de Seguridad Convergente	Aprobación del documento
1.1	24/07/2026	El consultor	Ampliación de ejemplos de clasificación (§5) y alta de §5.1 (retención de datos personales).
1.1	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.1.
1.2	24/07/2026	El consultor	Precisión de §3 (regla de versionado) y §4 (tabla de tipos documentales y aprobaciones). Ver decisiones.md §16.
1.2	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.2.
1.3	20/08/2026	El consultor	Recorte del historial de versiones a una línea por entrada, con referencia a decisiones.md donde procede. Sin cambios de fondo.
1.3	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.3.
1.4	20/08/2026	El consultor	Alta de SGSI-REG-008 en el inventario de registros (§2, §4: seis registros, no cinco); alta en §5.1 de la retención de los expedientes de personal (T-05) y de los itinerarios de viaje (T-07), tratamientos identificados en SGSI-REG-008.
1.4	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.4.
1.5	20/09/2026	Autor del caso	Revisión de coherencia de septiembre. Deltas y verificación en docs/fase1-iso27001/correcciones_2026-09.md. Sin cambios en la fecha de corte.
1.6	27/09/2026	Autor del caso	Revisión por dominios aplicables y alcance de controles. Corte 24/07/2026 conservado. Aprobación pendiente. Deltas: revisión 2026-09-27.

1. Objeto

Establece cómo se crea, identifica, revisa, aprueba, distribuye, protege y retira la información documentada del SGSI de Atalaya Gestión Patrimonial SL (cláusula 7.5 de ISO/IEC 27001:2022). El criterio rector es la proporcionalidad: en una organización de nueve personas, un sistema documental pesado muere en tres meses; este procedimiento define el mínimo que garantiza control real.

2. Identificación y codificación

Tipo	Codificación y ejemplos
Documentos del SGSI	SGSI-DOC-NNN: políticas, procedimientos, normas y metodologías (p. ej., SGSI-DOC-003 Política de Seguridad de la Información).
Registros	SGSI-REG-NNN: evidencias y registros vivos (p. ej., SGSI-REG-001 Registro de riesgos, SGSI-REG-003 Declaración de Aplicabilidad, SGSI-REG-008 Registro de Actividades de Tratamiento).
Acuerdos	SGSI-ACU-NNN: acuerdos específicos con el círculo de confianza y anexos de seguridad a contratos de terceros.
Informes	SGSI-INF-NNN: informes puntuales a la propiedad o al Comité (p. ej., SGSI-INF-001 Informe ejecutivo para la propiedad).

Todo documento lleva cabecera de control (código, versión, estado, clasificación, propietario, autor, fechas), historial de versiones y pie con clasificación, código y paginación. En los registros mantenidos en libro de cálculo, la cabecera de control y el historial ocupan la hoja «Portada» del libro y el pie se configura en todas sus hojas: el soporte cambia, el requisito no.

3. Estados y versionado

Estados: Borrador (en elaboración o revisión), Vigente (aprobado y en vigor) y Obsoleto (retirado, conservado como histórico). Una revisión nueva no sustituye a la vigente hasta su aprobación. Las entregas anteriores denominadas «Revisión documental pendiente de aprobación» se interpretan como Borrador. El índice identifica por documento su versión, estado y ubicación; conservar una entrega no significa que todos sus archivos estén aprobados. Versionado: 0.x para la elaboración inicial; 1.0 para la primera aprobación. Las revisiones posteriores usan el siguiente número previsto y mantienen estado Borrador hasta aprobación. Se incrementa el entero cuando cambia el alcance, los criterios de riesgo, el gobierno o la estructura de registros; el decimal para ajustes menores. La revisión de la regla y la estructura de REG-001/002 de 27/09/2026 se identifica como 2.0. El ciclo histórico de julio conserva su numeración original.

4. Elaboración, revisión y aprobación

Documento	Revisa	Aprueba
Política de seguridad (DOC-003)	Comité de Seguridad Convergente	Administrador único (la declaración de compromiso, §3) / Comité de Seguridad Convergente (el desarrollo, §§4-9, por delegación expresa)
Metodologías, normas, políticas de desarrollo y procedimientos	Propietario del documento	Comité de Seguridad Convergente
Registros del SGSI	Propietario del registro	Los seis registros vigentes del sistema — SGSI-REG-001/002, REG-003, REG-004, REG-005, REG-006 y REG-008— se

Documento	Revisa	Aprueba
		aprueban en sesión del Comité, por acuerdo expreso adoptado al cierre del diseño: todos contienen decisiones que la dirección debe hacer suyas, no solo datos. Un registro futuro que se limite a acumular evidencia operativa no requerirá aprobación formal, y el Comité lo hará constar al darlo de alta.
Acuerdos con terceros y círculo de confianza	Dirección General + asesoría legal	Dirección General
Contexto, alcance y objetivos (DOC-001, DOC-005)	Propietario del documento	Comité de Seguridad Convergente
Informes a la propiedad y al Comité (SGSI-INF-NNN)	Comité de Seguridad Convergente	Comité de Seguridad Convergente; los emite la Dirección General

Revisión programada: anual como mínimo para todos los documentos vigentes, y siempre tras un incidente relevante o un cambio del contexto (SGSI-DOC-001, sección 8).

5. Clasificación de la información

Cuatro niveles, aplicables a toda la información en alcance, no solo a los documentos del SGSI:

Nivel	Definición	Ejemplos
Restringida	Su exposición habilita daño directo a personas o disposición patrimonial. Acceso nominal, cifrado obligatorio en tránsito y reposo, prohibida en mensajería personal.	Rutinas, itinerarios de viaje, dispositivos de protección, pólizas personales, poderes, posiciones bancarias; existencia, fecha e importe de movimientos de efectivo o valores (SGSI-DOC-007 §6, regla E2); fichas de evaluación de destino y listas de destinatarios de itinerario (SGSI-DOC-008 §6)
Confidencial	Información patrimonial, contractual o personal cuya exposición causa daño significativo.	Contratos, información fiscal, escrituras, datos del personal; registros nominales de acceso de contratas y de visitas (SGSI-DOC-006 §7 y §8); registro de indicios (SGSI-REG-004)
Interna	Operativa de la organización sin daño grave si se expone, pero no pública.	Documentos del SGSI, procedimientos, comunicaciones internas
Pública	Aprobada expresamente para difusión exterior.	Versión pública de la política, información de la agencia de comunicación

Regla práctica: en caso de duda entre dos niveles se aplica el superior. La información de rutinas y ubicaciones de la familia es siempre Restringida, con independencia de su soporte o de quién la genere.

5.1 Retención de los registros con datos personales

Los registros de acceso y de visitas introducidos por SGSI-DOC-006 constituyen tratamiento de datos personales (SGSI-REG-005, L-11) y no pueden conservarse indefinidamente por comodidad operativa. Se fijan aquí sus plazos, porque un registro sin plazo de borrado deja de ser un control y pasa a ser un riesgo por sí mismo.

Registro	Plazo de conservación	Criterio
Registro de acceso de contratas y trabajos (DOC-006 §7)	12 meses	Cubre un ciclo anual completo de auditoría y permite reconstruir intervenciones sobre sistemas y zonas.
Registro de visitas no contractuales (DOC-006 §8)	6 meses	Plazo mínimo para sostener la revisión semanal de correlación sin acumular información sobre relaciones personales de la familia más allá de su utilidad.
Registro de indicios (SGSI-REG-004)	24 meses	Los patrones de vigilancia hostil se despliegan en plazos largos; un plazo corto anula el valor de la correlación.
Grabaciones de videovigilancia	Un mes como máximo	Un mes como máximo desde la captación. La conservación excepcional se limita a las imágenes necesarias para acreditar actos contra personas, bienes o instalaciones, que se pondrán a disposición de la autoridad competente en las 72 horas desde que se conozca la existencia de la grabación pertinente (art. 22.3 LOPDGDD).
Registros de verificación de órdenes y movimientos (DOC-007)	6 años	Alineado con los plazos de conservación mercantil y con el valor probatorio del registro.
Expedientes de personal: nómina, Seguridad Social y control horario (SGSI-REG-008, T-05)	Por categoría documental; no se aplica un plazo único al expediente completo	El responsable financiero separa control horario, justificantes de Seguridad Social y documentación contable/fiscal y documenta la obligación y el cómputo aplicables en REG-005/T-05. Se retira la cita al art. 21 del Estatuto de los Trabajadores, que no regula conservación. La revisión jurídica de los plazos y el borrado correspondiente permanece abierta; no se declara cerrado el requisito por conservar todo indiscriminadamente.
Itinerarios y fichas de seguridad de destino (SGSI-DOC-008; SGSI-REG-008, T-07)	12 meses tras la finalización del viaje	Permite revisar patrones de exposición geográfica acumulada sin retener indefinidamente los desplazamientos de la familia.

Vencido el plazo, el borrado es efectivo y se documenta. La conservación más allá del plazo requiere motivo escrito vinculado a un incidente o a un procedimiento en curso.

6. Distribución, protección y documentos externos

– Repositorio único de documentos vigentes en el servidor del family office, con acceso por rol; se prohíbe la circulación de copias locales de documentos Restringidos y Confidenciales. En el repositorio público ficticio se separan versión vigente, revisión pendiente e histórico; GitHub conserva la trazabilidad de publicación, pero una publicación no equivale a aprobación del SGSI.

- La información documentada de origen externo necesaria para el SGSI (contratos con terceros, pólizas, requisitos legales) se identifica y controla en el mismo repositorio, con propietario asignado.
- La distribución a terceros exige versión y registro de entrega; a los miembros del círculo de confianza se les entrega únicamente lo que su acuerdo específico requiere.

Anexo A. Trazabilidad

Sección	Cláusula ISO/IEC 27001:2022
2, 3, 4 — Identificación, estados, aprobación	7.5.1, 7.5.2, 7.5.3
5 — Clasificación	Anexo A 5.12, A 5.13
6 — Distribución y externos	7.5.3; Anexo A 5.14